

VERIFICATION TO TEAM #1

➤ PITFALLS VERIFICATION (50)

In the activities.html file

❖ Pitfall 1

The openAssignModalFromForm() and OpenAssignes functions

Code duplication: both methods do the same thing except for how they get the ID

```
function openAssignModalFromForm() {  
  
    const id = document.getElementById('ActivityID').value;  
  
    if(!id) {  
  
        alert('Guarde la actividad antes de asignar una maestra.');  
        return;  
  
    }  
  
    document.getElementById('assignActivityID').value = id;  
  
    $('#assignModal').modal('show');  
  
}
```

❖ Pitfall 2

Methods with inconsistent names

- saveActivity()
- assignTeacher()
- openMediaModal()
- viewActivity()
- loadActivities()
- loadGradesAndTeachers()
- logic_delete_activity()
- openAssignModalFromForm()

saveActivity() mixes validation, packaging, file upload, backend logic, modal closing, and reloading, all in a single method.

```
/* Abrir modal subir material */  
  
function openMediaModal(activityID) {
```

```

document.getElementById('mediaActivityID').value = activityID;

document.getElementById('Caption').value = '';

document.getElementById('MediaType').value = 'Image';

document.getElementById('FilePath').value = '';

$('#mediaModal').modal('show');
}

```

❖ Pitfall 3

Duplicate code

- It does too many things (violation of the Single Responsibility principle). In the activity-media.html file
- The Topbar block appears repeated on several pages of the project (depending on your other files). This creates unnecessary duplication.
- The same set of Bootstrap, jQuery, and sb-admin scripts is also repeated across all views.

```

<!-- Sidebar -->

<ul

    class="navbar-nav bg-gradient-primary sidebar sidebar-dark
accordion"

    id="accordionSidebar"

>

    <!-- Sidebar dinámico se inyecta aquí (dynamic-sidebar.js) -->

</ul>

<!-- Bootstrap core JavaScript-->

<script src="../../vendor/jquery/jquery.min.js"></script>

<script
src="../../vendor/bootstrap/js/bootstrap.bundle.min.js"></script>

<script
src="../../vendor/jquery-easing/jquery.easing.min.js"></script>

<script src="../../js/sb-admin-2.min.js"></script>

```

```
<!-- utils.js SIEMPRE antes del dinámico -->
```

❖ Pitfall 4

Inconsistent names

- **ActivityMediaGallery** uses camelCase, but the rest of the HTML uses snake-case in some parts.
- **userDropdown**, **alertsDropdown**, and other IDs have English names while the system content is in Spanish → language inconsistency.
- **The List** view uses Spanish, but the button uses a "list" icon, and some of the content is in English. Language mix.

```
<div id="activityMediaGallery"
```

In the activity-calendar.html file:

❖ Pitfall 5

- Inline embedded styles `style = "minimumheight: 400px;"` in the calendar div → bad practice, breaks style separation.

```
<div class="card-body">
```

```
    <div id="activityCalendar" style="min-height:400px;"></div>
```

```
</div>
```

In the attendance.html file:

❖ Pitfall 6

Oversized functions:

- renderStudentRows()
- guardarFilaAsistencia()
- cargarEstudiantesPorGrado()
- cargarGrados()

Some have more than 50–100 lines = difficult to maintain.

```
function renderStudentRows(students){
  tbody.innerHTML = '';
  students.forEach((s, idx) => {
    const tr = document.createElement('tr');
    tr.dataset.studentId = s.StudentID;
    tr.innerHTML = `
      <td>${idx+1}</td>
      <td class="text-center"><input type="checkbox" class="presentChk form-control" /></td>
      <td>${escapeHtml(s.FirstName)} ${escapeHtml(s.LastName)}</td>
      <td><input type="time" class="form-control arrivalTime" value="${s.CheckInTime ?? ''}" /></td>
      <td><input type="time" class="form-control checkoutTime" value="${s.CheckOutTime ?? ''}" /></td>
      <td>
        <select class="form-control statusSel">
          <option value="Present">Present</option>
          <option value="Absent">Absent</option>
          <option value="Late">Late</option>
          <option value="Excused">Excused</option>
        </select>
      </td>
      <td><input type="text" class="form-control notesInput" placeholder="Notas..." value="${escapeHtml(s.Notes ?? '')}" /></td>
      <td class="text-center lateCell"><input type="checkbox" class="lateChk form-control" disabled ${s.IsLate ? 'checked' : ''} />
      <td class="text-center"><button class="btn btn-sm btn-primary saveBtn">Guardar</button></td>
    `;
    // eventos
  });
}
```

❖ Pitfall 7

Lack of validations

- It doesn't validate if the start date > end date
- It doesn't validate the backend date format.
- It doesn't validate consistency between CheckInTime and CheckOutTime.

❖ Pitfall 8

Dead code

- jQuery Easing is included, but not used.
- SB Admin 2 is included, but no template-specific JS functionality is activated in this table.

```
<script src=".../vendor/jquery-easing/jquery.easing.min.js"></script>
```

❖ Pitfall 9

Unsanitized data

- The server data is inserted without escaping, allowing XSS.
- Without error handling, the user sees a blank screen if it fails.

part of code:

```
// VULNERABLE -
```

```
b+=`<td>${p.EntityName}</td>` // <script>alert('XSS')</script>
```

```
b+=`<td>${o.Observation.slice(0,40)}</td>` //
```

```
b+=`<td>${g.FirstName} ${g.LastName}</td>` //
```

❖ Pitfall 10

URL Injection

- Observation is free text vulnerable to XSS. ObservationID in URLs can inject code. Validate that it is numeric.

part of code:

```
href="observation-detail.html?id=${o.ObservationID}"
```

```
href="guardian-detail.html?id=${g.GuardianID}"
```

```
data-id="${g.GuardianID}"
```

```
href="invoice-detail.html?iid=${f.InvoiceID}"
```

❖ Pitfall 11

No error handling

- AJAX requests without error handling leave the user without feedback when something goes wrong.

part of code:

```
$.get(API_BASE_URL+"/payments/teacher/get_all.php",function(r){
```

```
});
```

```
$.ajax({
```

```
  url: url,
```

```
  method: "POST",
```

```
  success: function(resp){ }
```

```
});
```

❖ Pitfall 12

Duplicate event handlers

- Adding event handlers without removing the previous ones causes the event to run multiple times.

part of code:

```
function loadGuardians(){
```

```

$(".btn-edit").click(function(){ // Each refill adds NEW handler

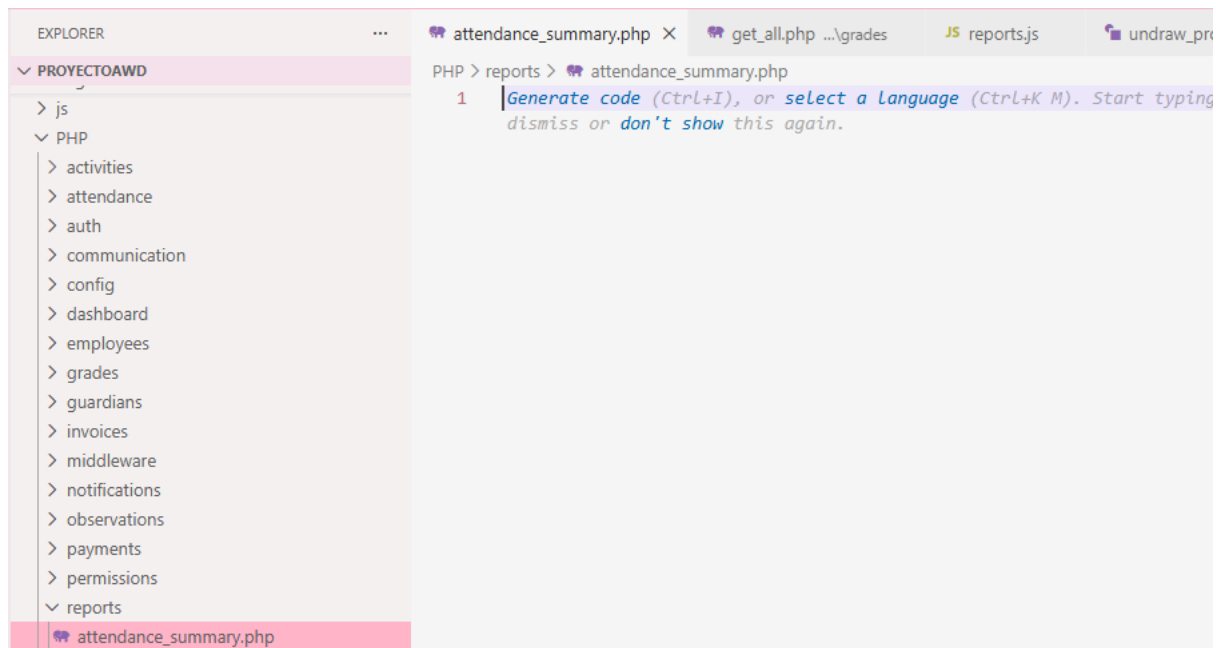
});

}

```

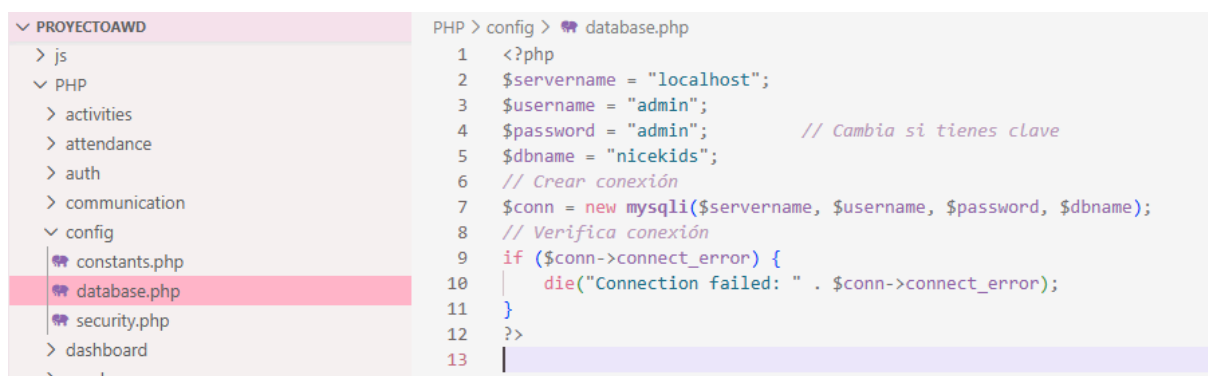
❖ Pitfall 13:

Dead Files/Orphan files in the overall project. In folder like “PHP” most files don’t have a single line of code, like: create.php, and files related to report (both in JS folder and PHP folder). This pitfall creates false structure, difficult code review and increase complexity.



❖ Pitfall 14:

Duplicated connection to database. The connection is first stated in php/config/database.php. But later there’s a file in tools/db_chek.php where the code is duplicated with a certain code addition to an amplified connection handler. This could be removed and unified in a single DB connection file to avoid confusion.



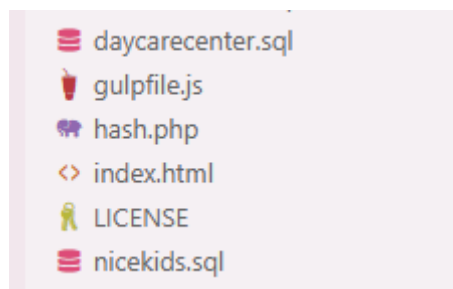
```

1 <?php
2 header('Content-Type: application/json');
3
4 // Ajusta estas credenciales si tu entorno es distinto
5 $dbHost = 'localhost';
6 $dbUser = 'admin';
7 $dbPass = 'admin';
8 $dbName = 'nicekids';
9
10 $result = ['success' => false];
11
12 $mysqli = @new mysqli($dbHost, $dbUser, $dbPass, $dbName);
13 if ($mysqli->connect_errno) {
14     $result['error'] = $mysqli->connect_error;
15     $result['errno'] = $mysqli->connect_errno;
16 } else {
17     $result['success'] = true;
18     $result['message'] = 'Conectado a MySQL ' . $mysqli->server_info . '
19     // opcional: una consulta simple para confirmar permisos
20     $res = $mysqli->query("SELECT 1");
21     $result['query_ok'] = $res ? true : false;
22     $mysqli->close();
23 }
24
25 echo json_encode($result);

```

❖ Pitfall 15:

Duplicated database. In the project there are 2 SQL database files (nicekids.sql and daycarecenter.sql). Should delete the one that is not being used.



❖ Pitfall 16:

Lack of formatting (both horizontal and vertical). One of the style file is all in one line of code.

```

1 /*!
2 * Start Bootstrap - SB Admin 2 v4.1.3 (https://startbootstrap.com/theme-
3 * Copyright 2013-2021 Start Bootstrap
4 * Licensed under MIT (https://github.com/StartBootstrap/startbootstrap-
5 *//*!
6 * Bootstrap v4.6.0 (https://getbootstrap.com/)
7 * Copyright 2011-2021 The Bootstrap Authors
8 * Copyright 2011-2021 Twitter, Inc.
9 * Licensed under MIT (https://github.com/twbs/bootstrap/blob/main/LICEN
10 */:root{--blue:#4e73df;--indigo:#6610f2;--purple:#6f42c1;--pink:#e

```

SYSTEM VERIFICATION (12/50)

➤ REPORT (6/10)

- **UPDATE/CREATE (6/10)**
- **BUSINESS RULES (0/10)**
- **PDF REPORT (0/10)**

The project includes some code files related to pdf, report, update/create but as the system doesn't work it can't be verified if the system is doing these things properly.

It was needed that the main inspector imported their database in phpMyAdmin, and changed connection files to try and make the project compile. Anyway, database doesn't have relevant data and the only functionality working is the creation of a student (which isn't validated and has logic problems in the dates).

- PDF Report and reports in general:

Not Found

The requested URL was not found on this server.

- Create without validation:

[← Volver](#)

Agregar Nuevo Estudiante

Información Personal

Nombre *

Apellido *

Fecha de Nacimiento *

Género *

Femenino

Número de Documento

Grado *

Seleccione un grado

Correo Electrónico

Teléfono

Dirección

Foto de Perfil

Seleccionar archivo

Sin archivos seleccionados

Fecha de Inscripción

Formatos: JPG, PNG. Tamaño máximo: 2MB

Update/delete students work from DB to system and vice versa.

Columna	Tipo	Función	Nulo	Valor
StudentID	int(11)		☐	1
FirstName	varchar(50)		☐	Saray
LastName	varchar(50)		☐	Canarte
BirthDate	date		☐	2025-11-29
Gender	enum	--	☐	F
DocumentNumber	varchar(20)		☐	erfa2313

Lista de Estudiantes

ID	Foto	Nombre Completo	Fecha Nac.	Edad	Género	Grado	Tipo	Estado	Acciones
1		Saray Canarte	2025-11-29	-	F	-	Recurrente	Activo	

Teacher CRUD operations don't work. There's not even a table for teachers in the database.


Datos del Representante
×

Nombre *
☒

Apellido *
☒

Documento *
☒

Relación *
☒

Teléfono *
☐

El teléfono es obligatorio.

Email *
☐

Ingrese un email válido.

Dirección *
☒

GuardianID	FirstName	LastName	DocumentNumber	Relationship	PhoneNumber	Email	Address	Occupation	WorkPhone	Is
1	dfadf	dfg123123	123	Padre	123	werewr@as.com		-..wer	0	

Guardian creation lacks, again, proper validation. Update from app doesn't work (not available).

Rest of the operations don't work either. Buttons don't do anything, grades are not loaded (there's no data in the database to load).

- No business rule working or found.